



MARCO DEL SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN (SGSI)

BY NOVA TECH SOLUTIONS

1. CONTEXTO ORGANIZACIONAL

NovaTech Solutions es una empresa mexicana ubicada en la ciudad de Monterrey, México, que cuenta con una plantilla activa de 120 empleados. La organización opera en el sector tecnológico y se dedica al desarrollo de software, creación de plataformas web y prestación de servicios digitales orientados a pequeñas y medianas empresas. Durante los últimos cinco años, la empresa ha experimentado un crecimiento acelerado y vertiginoso, pasando de ser un estudio pequeño a una compañía con clientes a nivel nacional. Este ritmo de expansión trajo consigo un incremento significativo en el volumen de datos gestionados, una mayor complejidad en la infraestructura y nuevas dependencias tecnológicas que, en consecuencia, elevaron los riesgos operativos.

Actualmente, NovaTech Solutions carece de un Sistema de Gestión de Seguridad de la Información formal y no posee políticas de seguridad establecidas. La protección de la empresa depende de controles tecnológicos aislados y carece de una gestión estructurada de riesgos, lo cual representa una debilidad estructural significativa ante amenazas internas y externas. Para mitigar estos riesgos y alinear la seguridad con los objetivos del negocio, el SGSI se implementará sobre las cuatro áreas operativas principales de la organización:

- **Desarrollo de software:** Área responsable del desarrollo y mantenimiento de plataformas web, así como de la gestión de repositorios de código mediante entornos Git y servidores de integración continua.
- **Atención a clientes:** Departamento encargado de brindar soporte técnico, gestionar las solicitudes y administrar la información personal y de contacto de los clientes mediante sistemas CRM y bases de datos.
- **Administración:** Responsable de los procesos de facturación, contratos, recursos humanos y gestión de información financiera y datos personales de los empleados.
- **Infraestructura tecnológica:** Área encargada de administrar y mantener las bases de datos, los servidores y el almacenamiento alojado en la nube, así como el correo corporativo y las aplicaciones web.

2. ALCANCE DEL SGSI

El alcance del Sistema de Gestión de Seguridad de la Información (SGSI) se define para proteger los activos de información que sostienen los procesos operativos de NovaTech Solutions, garantizando en todo momento su Confidencialidad, Integridad y Disponibilidad.

Límites Físicos:

- Las instalaciones corporativas y oficinas de operación de NovaTech Solutions centralizadas en Monterrey, México.

Límites Lógicos y Tecnológicos:

- Repositorios de código fuente (Git) y ambientes de desarrollo utilizados para la creación y mantenimiento de plataformas de clientes y productos SaaS.
- Sistemas CRM, correos electrónicos corporativos y bases de datos utilizados por el área de Atención a Clientes para la prestación de soporte.
- Toda la infraestructura tecnológica crítica tercerizada, incluyendo servidores web y servicios de almacenamiento en la nube.

Procesos Críticos de Negocio Cubiertos:

- **Protección de Propiedad Intelectual:** Aseguramiento de la confidencialidad y la integridad del código fuente alojado en los repositorios para prevenir accesos indebidos, descargas no autorizadas o modificaciones maliciosas que comprometan los proyectos.
- **Gestión y Tratamiento de Datos Personales:** Protección integral de la información personal tanto de clientes como de empleados gestionada en los sistemas CRM y bases de datos de recursos humanos, garantizando el cumplimiento estricto de la legislación mexicana vigente.
- **Continuidad de la Infraestructura en la Nube:** Monitoreo y protección de las bases de datos y servidores en la nube para asegurar la disponibilidad continua de los servicios y mitigar el riesgo de interrupciones prolongadas o pérdida de datos por fallas de configuración.
- **Protección Administrativa y Financiera:** Resguardo de la información financiera, documentos contractuales y credenciales de acceso a sistemas administrados por los equipos internos.

3. OBJETIVOS DE SEGURIDAD

Los objetivos de seguridad de NovaTech Solutions están diseñados para ser el pilar que soporte el crecimiento del negocio y la confianza de nuestros clientes, alineándose directamente con la visión de la Dirección General.

- **Objetivo 1: Garantizar la Continuidad de los Servicios Digitales y SaaS.**
Promover la disponibilidad constante de las plataformas web y sistemas CRM, con acciones destinadas a reducir al mínimo las interrupciones que impacten a las PyMEs clientes.
 - **Justificación CIA:** Este objetivo se centra en la Disponibilidad, asegurando que la infraestructura tecnológica crítica esté operativa cuando el negocio y los clientes la necesiten, evitando interrupciones como la caída de 6 horas experimentada previamente.
- **Objetivo 2: Salvaguardar la Propiedad Intelectual y el Código Fuente.**
Implementar controles de acceso y monitoreo estricto en todos los repositorios Git, con el objetivo de minimizar el riesgo de exfiltración o modificación no autorizada de productos SaaS propios.
 - **Justificación CIA:** Protege la Confidencialidad (evitando accesos no autorizados a algoritmos propios) y la Integridad (asegurando que el código no sea alterado maliciosamente), lo cual es vital para la ventaja competitiva de la empresa.
- **Objetivo 3: Asegurar el Cumplimiento de la LFPDPPP y Privacidad de Datos.**
Establecer un marco de control que garantice el tratamiento lícito de los datos personales de los 120 empleados y de la base de datos de clientes, eliminando las filtraciones por error humano.
 - **Justificación CIA:** Se enfoca en la Confidencialidad y la Integridad de los datos sensibles, asegurando que solo el personal autorizado acceda a ellos y que la información no sea divulgada a terceros de forma accidental o errónea.
- **Objetivo 4: Fortalecer la Resiliencia Operativa mediante la Gestión de Riesgos.**
Identificar y mitigar de manera sistemática los riesgos críticos detectados mediante la metodología OCTAVE Allegro antes del cierre del ciclo anual, con el objetivo de reducir su impacto en la operación.

- **Justificación CIA:** Impacta de forma integral en la Triada CIA, ya que permite anticipar amenazas que podrían comprometer la privacidad, la veracidad o el acceso a la información estratégica del negocio.

4. ROLES Y ESTRUCTURA ORGANIZACIONAL

Para asegurar el éxito del SGSI, se define la siguiente estructura de gobernanza, donde cada rol tiene responsabilidades específicas sobre los activos de información de NovaTech Solutions.

- **Dirección** **General:**
Es el máximo órgano de decisión. Su responsabilidad incluye la aprobación formal del presupuesto para seguridad, el respaldo a las políticas de cumplimiento y la revisión periódica del desempeño del SGSI para asegurar su alineación con los objetivos comerciales.
- **Comité de Seguridad de la Información (Consultoría Senior):**
Actuando como los arquitectos del sistema, este equipo es responsable de diseñar, implementar y documentar el SGSI basado en ISO 27001. Sus funciones incluyen la realización de la evaluación de riesgos, la redacción de políticas y la supervisión de que los controles propuestos se ejecuten correctamente.
- **Propietarios de Activos (Gerentes de Área):**
Los responsables de las áreas de Desarrollo, Atención a Clientes, Administración e Infraestructura actúan como dueños de la información en sus respectivas áreas. Deben clasificar sus activos, definir quién tiene acceso a ellos y garantizar que su equipo siga las directrices de seguridad establecidas en el SGSI.
- **Equipo de Respuesta a Incidentes (CSIRT):**
Un grupo especializado encargado de actuar de forma inmediata ante cualquier evento que comprometa la seguridad, como accesos sospechosos a repositorios o fallas en servidores en la nube. Su función principal es la contención, análisis y recuperación rápida de la operación.
- **Usuarios Finales (Colaboradores):**
Los 120 empleados de NovaTech son responsables de cumplir con las políticas de seguridad (como el cierre de sesiones y el uso correcto del correo) y participar activamente en los programas de concientización para reducir la probabilidad de incidentes por error humano.

5. RELACIÓN CON ISO/IEC 27001

El SGSI de NovaTech Solutions se diseña tomando como marco de referencia principal el estándar internacional ISO/IEC 27001. Esta norma proporciona la estructura fundamental para el establecimiento, implementación, mantenimiento y mejora continua del sistema.

La organización utilizará este estándar para:

- Gobernar la estructura documental y los procesos de seguridad de manera sistemática.
- Guiar la selección y aplicación de controles de seguridad técnicos, administrativos y físicos adaptados a las necesidades del negocio.
- Asegurar que la seguridad de la información no sea un esfuerzo aislado, sino una capacidad organizacional estratégica y alineada con las mejores prácticas globales.

6. RELACIÓN CON LA LEGISLACIÓN APLICABLE

Como empresa mexicana con sede en Monterrey, NovaTech Solutions tiene la obligación legal y el compromiso ético de proteger la privacidad de las personas. El SGSI garantiza el cumplimiento estricto del marco normativo.

Este marco legal es crítico dado que la empresa gestiona:

- **Datos de Clientes:** Información personal, de contacto y técnica almacenada en el sistema CRM y bases de datos comerciales.
- **Datos de Empleados:** Información sensible de los 120 colaboradores gestionada por el área de Administración y Recursos Humanos.

El SGSI establece los controles necesarios para cumplir con los principios de licitud, consentimiento, información y responsabilidad que exige la ley, mitigando riesgos de sanciones legales y daños reputacionales.

7. MODELO DE GESTIÓN DE RIESGOS

NovaTech Solutions adopta oficialmente la metodología OCTAVE Allegro como su modelo estándar para la evaluación y gestión de riesgos de seguridad de la información. A diferencia de otros enfoques, OCTAVE Allegro permite una evaluación exhaustiva centrada en los activos de información en su contexto operativo.

El proceso de gestión de riesgos se priorizará sobre los activos críticos identificados, tales como:

- **Código Fuente:** Protegiendo la propiedad intelectual y los repositorios Git frente a accesos no autorizados o alteraciones.
- **Sistema CRM:** Asegurando la integridad y disponibilidad de la plataforma de atención a clientes y sus bases de datos asociadas.

Este modelo permitirá identificar amenazas y vulnerabilidades de manera proactiva, facilitando la toma de decisiones informadas para la mitigación de riesgos.

8. CICLO DE MEJORA CONTINUA

Para garantizar que el SGSI sea un sistema dinámico y resiliente, NovaTech Solutions operará bajo el modelo de mejora continua PDCA (Plan-Do-Check-Act):

1. **Plan (Planificar):** Establecer los objetivos de seguridad, evaluar los riesgos mediante OCTAVE Allegro y diseñar los controles y políticas necesarios.
2. **Do (Hacer):** Implementar las políticas de seguridad, ejecutar los controles seleccionados y realizar los programas de capacitación y concientización para el personal.
3. **Check (Verificar):** Monitorear el desempeño del sistema a través de métricas e indicadores clave (KPIs), realizar auditorías internas y revisar la efectividad de la respuesta a incidentes.
4. **Act (Actuar):** Tomar acciones correctivas basadas en los resultados de la verificación para cerrar brechas de seguridad y ajustar el sistema ante nuevos cambios en el entorno tecnológico de la empresa.